

ITT320 INTRO TO COMPUTER SECURITY

Chapter 7 : Operating System Hardening

Zulazeze Sahri, UiTM



Objectives

- Properly configure a secure Windows system
- Properly configure a secure Linux system
- Apply appropriate operating system patches to Windows
- Securely configure a Web browser



Introduction

Securely configuring the operating system and its software is a critical step in system security that is often neglected.

This chapter takes you through this process for different operating systems.

It is not enough to just implement firewalls and proxy servers, it is also important to secure internal machines and the applications and information they house.



OS Hardening

Hardening of the OS is **the act of configuring an OS securely, updating it, creating rules and policies to help govern the system** in a secure manner, and removing unnecessary applications and services.

- To reduce the chance of a computer operating system becoming vulnerable to attacks
- This chapter focuses on Windows Operating System in General

What You Need to do to Secure Your OS : **Accounts | Users | Groups | Password**

1. There are default user accounts – Win Server, DB
2. Administrator accounts – Change Default Username and Password
3. Other accounts
   IUSR_Machine Name / ASP.NET / Database Accounts / Phpmyadmin

OS Hardening

What You Need to do to Secure Your OS : **Accounts | Users | Groups | Password (Cont.)**

- Disable Those Accounts That are Not Being Used
- Avoid Using Default Accounts if Possible – Ask for Change Password
- Restrict User Access – Downloading/Installing/Access To Server/VPN
- Configuring System and Network Components Properly
- Deleting Unused Files and Folders
- Applying the Latest Patches

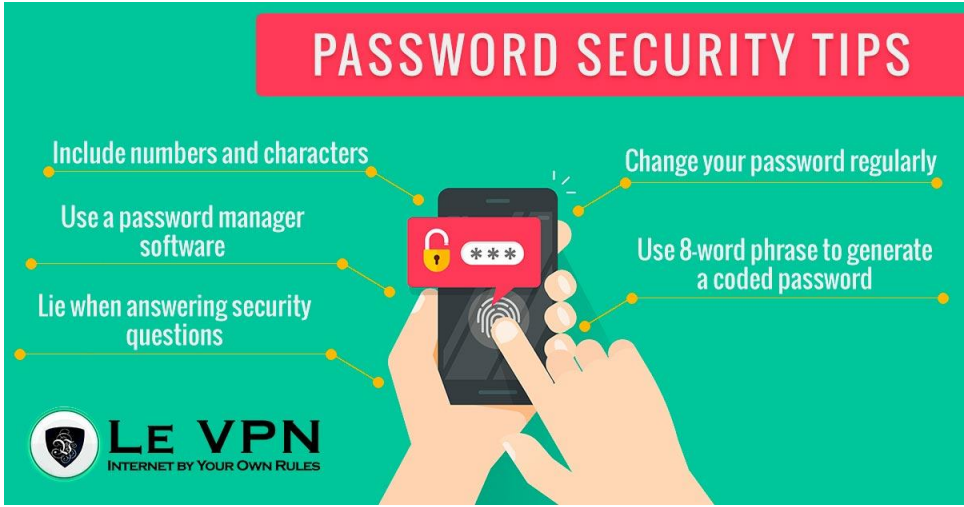


"To provide your clients with peace of mind, safeguard their sensitive data,
and differentiate your security offerings from others"

Configuring Windows Properly

Setting Security Policies : User error can lead to a successful cyberattack, we need to create and update user policies and make sure all users are aware of and compliant with these procedures

1. Password policies
2. Account lockout policies
3. See tables 7.1 – 7.4 for recommended policies
4. Other issues
    i. Writing passwords down
    ii. Sharing passwords
    iii. Using the “least required access” rule



Configuring Windows Properly – Password Policy

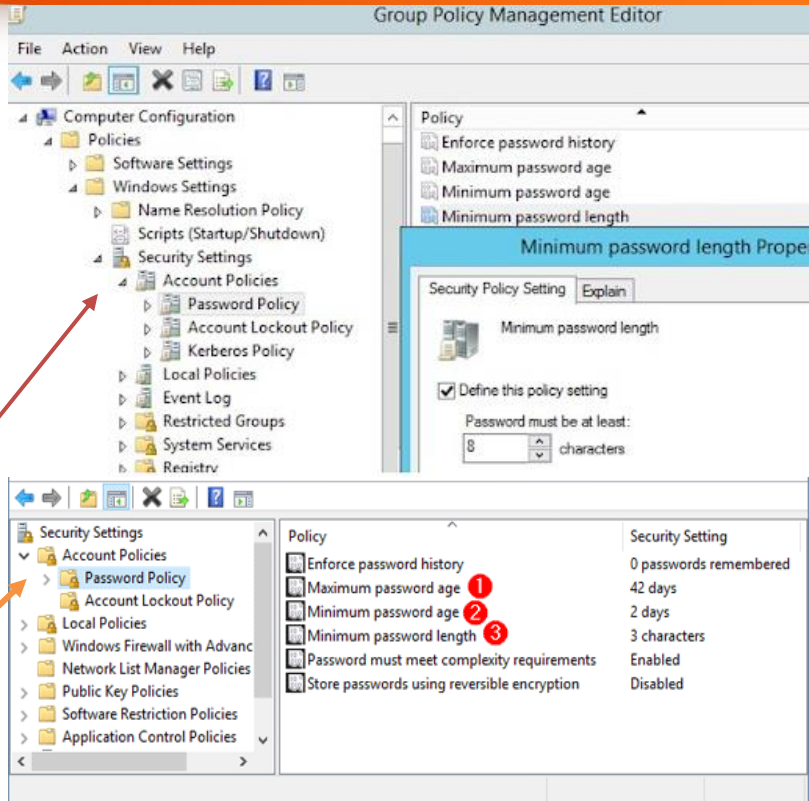
Default Windows Password Policies

Enforce password history	1 password remembered
Maximum password age	42 days
Minimum password age	0 days
Minimum password length	0 characters
Passwords must meet complexity requirements	Disabled
Store password using reversible encryption for all users in the domain	Disabled

Table 7.1 Default Windows Password Policies

Group Policy Management

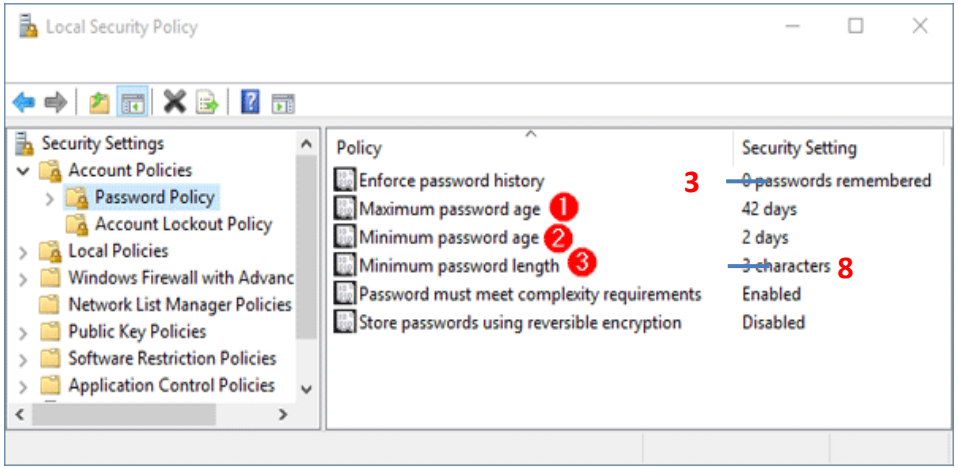
Local Policy Management



Configuring Windows Properly - Password Setting Recommendations

Policy	Microsoft	NSA	Author
Password history	3	5	3
Maximum password age	42	42	60 days. I recommend this because 42 is a rather odd number. Also, changing passwords too frequently causes end users to forget passwords.
Minimum password age	2	2	2
Minimum password length	8	12	I recommend 8 for most organizations, but for situations requiring more enhanced security the NSA guideline should be used.
Passwords must meet complexity requirements	No recommendation (left to user discretion)	Yes	Yes
Store password using reversible encryption for all users in the domain	No recommendation (left to user discretion)	No recommendation	No recommendation (left to user discretion)

Table 7.2 Default Windows Password Policies





Configuring Windows Properly-Windows Lockout Policy

Account **lockout policies** are used by administrators to lock out an account when someone tries to log on unsuccessfully several times in a row.

- Account Lockout Duration
  - Policy setting determines the number of minutes that a locked-out account remains locked out before automatically becoming unlocked
- Account Lockout Threshold
  - Policy setting determines the number of failed sign-in attempts that will cause a user account to be locked. E.g. 3 Times Attempts
- Reset Account Lockout Counter After
  - The number of minutes that must pass after a user fails to log on before the failed logon attempt counter is reset to zero

Configuring Windows Properly-Windows Lockout Policy

Account lockout duration	Not defined
Account lockout threshold	0 invalid log on attempts
Reset account lockout counter after	Not defined

Table 7.3 Windows Default Account Lockout Policies

RECOMMENDED

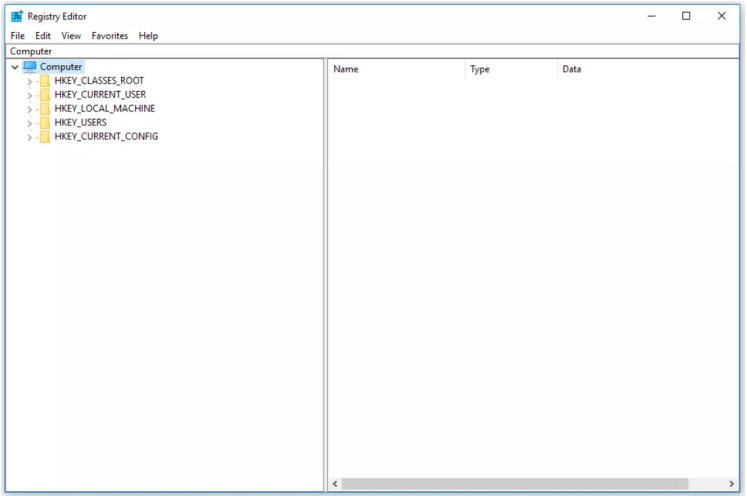
Policy	Microsoft	NSA	Author
Account lockout duration	0, indefinite	15 hours	48 hours. If someone is attempting to crack passwords on weekends/ holidays, you want the account locked until an administrator is aware of the attempt.
Account lockout threshold	5	3	3
Reset account after	15	30	30

Table 7.4 Recommended Account Lockout Policies

Configuring Windows Properly-Registry Settings

The **Windows Registry** stores much of the information and **settings** for software programs, hardware devices, user preferences, and operating-system configuration.

Registry settings can be altered to increase your computer security.

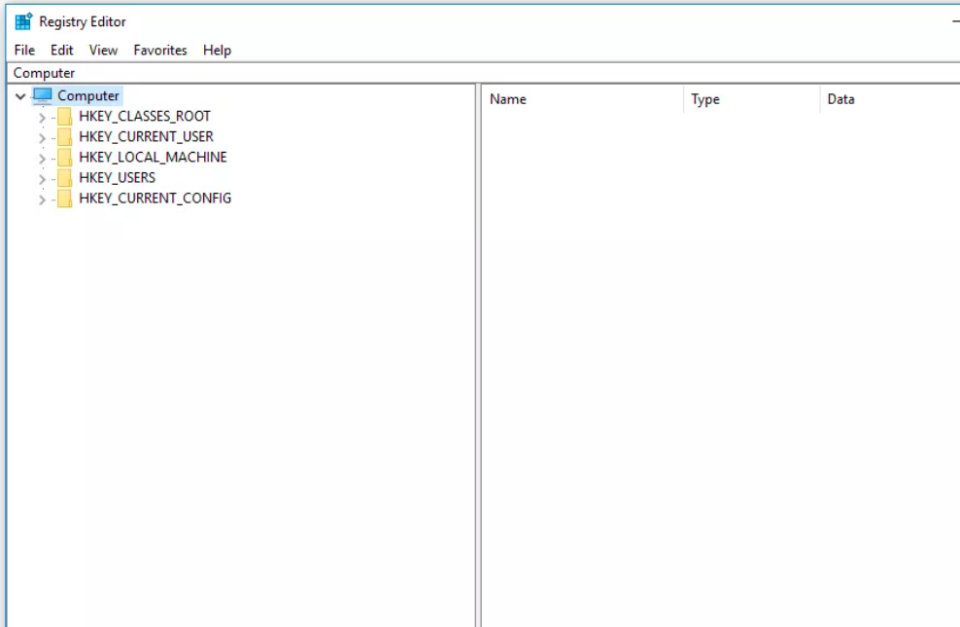


- Registry basics
- Secure registry settings
- Restrict Null session access
- Restrict Null session access over named pipes
- Restrict anonymous access

Configuring Windows Properly-Registry Basics

Registry Basics:
Core registry folders in the registry

- HKEY_CLASSES_ROOT
- HKEY_CURRENT_USER
- HKEY_LOCAL_MACHINE
- HKEY_USERS
- HKEY_CURRENT_CONFIG





Configuring Windows Properly-Registry Settings

Registry settings (Continued)

1. TCP/IP Stack settings – A method for protecting a system against DoS attacks. This method involves reconfiguring the operating system to handle connections differently
2. Default Shares - Certain drives/folders are shared by default. Leaving them shared like this presents a security hazard. Registry setting is required to overcome this problem.
3. Remote access to the registry
4. Other registry settings

Table 7.5 TCP/IP Stack Registry Settings

Key path	Recommended value
DisableIPSourceRouting	2
EnableDeadGWDetect	0
EnableICMPRedirect	0
EnablePMTUDiscovery	0
EnableSecurityFilters	1
KeepAliveTime	300,000
NoNameReleaseOnDemand	1
PerformRouterDiscovery	0
SynAttackProtect	2
TcpMaxConnectResponseRetransmissions	2
TcpMaxConnectRetransmissions	3
TCPMaxPortsExhausted	5

HKML\SYSTEM\CurrentControlSet\Services\Tcpip

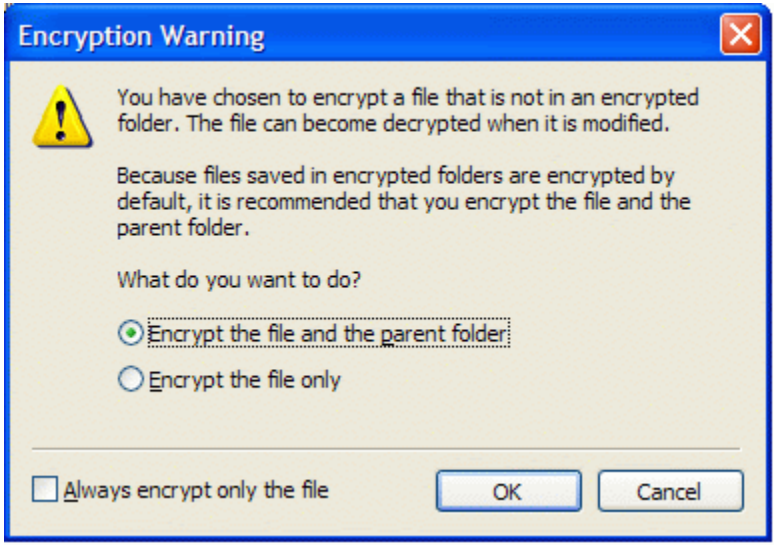
Configuring Windows Properly-Services

Services

- Shutting down a service in Windows
- Port filtering and firewalls in Windows

Encrypting File System (EFS)

- User interaction
- Virtually transparent to the user
- Built into Windows and easy to use



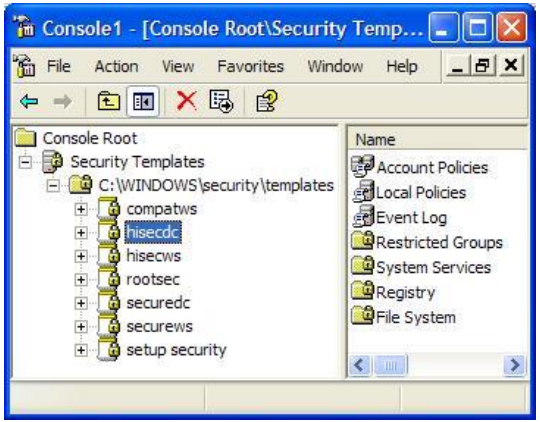
http://ntfs.com/using-encrypted-files.htm

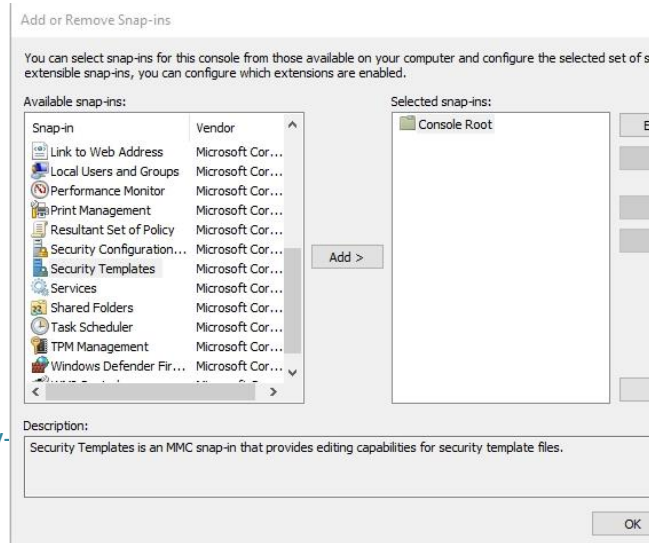
Configuring Windows Properly-Security Templates

Security Templates - often used by corporate environments and are essentially text files that represent a security configuration.

To help manage your group policy and ensure consistency across your entire organization

1. DC security.inf
2. Hisecdc.inf
3. Hisecws.inf
4. Securedc.inf
5. Securews.inf
6. Setup security.inf





https://docs.microsoft.com/en-us/troubleshoot/windows-server/identity/define-security-templates-snap-in

Configuring Linux Properly

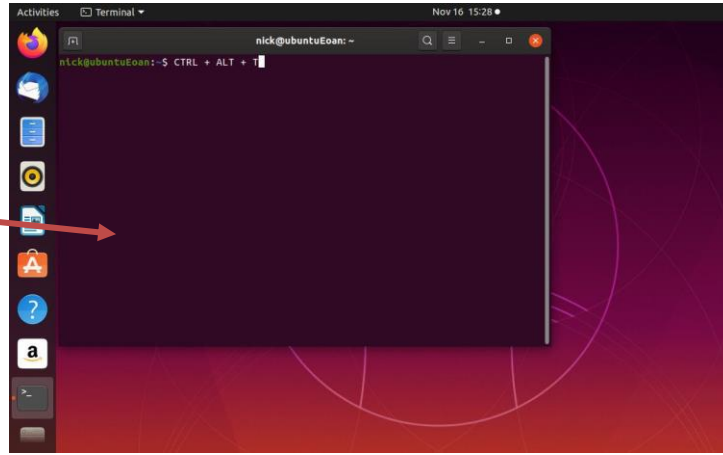
- Many security principles apply in Linux as they do in Windows

- Commonalities between Windows and Linux
  - Default users and policies (names are different)
  - All services not in use should be shutdown
  - Browser must be configured securely
  - Routinely patch the system



Configuring Linux Properly

- Differences between Linux and Windows
  - No application should run as the root user
  - Complexity of the root password
  - Disable all console-equivalent access for regular users
  - Hide system information



Web sites that provide additional help:

https://linuxsecurity.com/howtos

https://www.linux.com/topic/security/

https://securityboulevard.com/2020/08/linux-server-security-10-linux-hardening-security-best-practices/

https://blog.avast.com/secure-your-linux-server-avast

Configuring Linux Properly – Patching the OS

Patches have the particularly important role of fixing security holes.

Patch Management System is a software that manages and regularly updates the missing software patches in a network of computers.



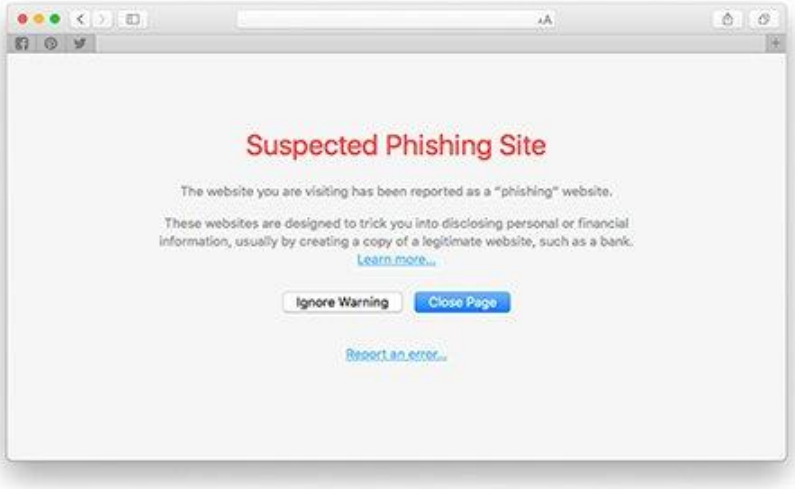
- Windows has updates on the Microsoft web site and Automated Patch updates in user's computer
- RedHat has a site that also allows updates to be made to its OS

Configuring Linux Properly – Configuring Browsers

- Usually, the web browser that comes with an operating system is not set up in a secure default configuration.
- Can caused spyware being installed without your knowledge to intruders taking control of your computer.

Browser Security & Privacy settings such as :

1. Keep your browsers up to date
2. Enable automatic updates for your browser
3. Block pop-ups, plug-ins and phishing sites (AV)
4. Set your browser not to store passwords



Configuring Linux Properly – Configuring Browsers Cont.

Browser Security & Privacy settings such as :

5. Disable third-party cookies
6. Prompt for first-party cookies & Always allow session cookies
7. Browser-specific settings:
    1. Firefox: install the uBlock Origin add-on
    2. Safari: disable Java
    3. IE: set up security zones



Security settings :
https://its.ucsc.edu/software/release/browser-secure.html



SUMMARY

- Hardening of operating systems is a critical part of Network security
- Proper security configuration can make hacking more difficult
- Encrypted File System (EFS) can secure information on the local computer
- Proper registry settings are also key in a Windows environment
- Failure to address registry settings will greatly reduce the security of the computer
- Securing the browser can limit exposure to malware

References

https://www.connectwise.com/blog/cybersecurity/6-important-os-hardening-tips-to-protect-your-clients

https://www.techtarget.com/search/query?q=operating+system+security

https://www.lifewire.com/windows-registry-2625992